TLS Vulnerabilities

Demonstrating attacks against three recent TLS vulnerabilities in an isolated environment

Proof of Concept

CVE-2025-23419 · CVE-2024-37309 · CVE-2025-66491

Goal & environment

Goal: reproduce three recent TLS vulnerabilities, show their effect, and show the fix removes them.

Environment: everything runs on our own host — Docker containers on a private network, bound to 127.0.0.1. No external or production system is touched.

Method: each vulnerability is run against two servers — a **vulnerable** version (must be affected) and a **patched** version (must be safe). The patched server is the control.

Scope: a controlled proof of concept — we reproduce known, already-patched CVEs using published advisories and standard tooling. No new exploit development, and nothing outside our own environment.

Tools

Hardware

- One host - PC, laptop or VM (8 GB RAM, ~15 GB disk)
- Docker (or a VirtualBox VM)
- No external network - loopback only

Software

- **Docker** - vulnerable + patched official images
- **k3d / kind** - small local Kubernetes (Traefik demo)
- **OpenSSL** CLI - handshakes, renegotiation
- **testssl.sh / nmap** - scanning
- **Wireshark** - inspect the handshake

Targets: nginx, CrateDB, Traefik — all official images.

The three vulnerabilities

CVE	Software	What it allows	Fixed in
CVE-2025-23419	nginx	Client-certificate auth bypass via session resumption	1.27.4 / 1.26.3
CVE-2024-37309	CrateDB	CPU denial of service via TLS renegotiation	5.7.2
CVE-2025-66491	Traefik	Backend cert verification silently disabled → MITM	3.6.3

Three different weakness classes: an **authentication bypass**, a **denial of service**, and **improper certificate validation** enabling a man-in-the-middle.

CVE-2025-23419 · nginx · authentication bypass

Client-cert bypass via TLS session resumption

What it is: when several nginx server blocks share one IP:port and the default server requires a client certificate, a TLS session resumed with a session ticket or cache entry can reach a protected server block **without presenting the certificate again**.

Demo: we configure two server blocks on one port (one requires a client cert), open a valid session, then resume it to reach the protected block with no cert. Vulnerable build → access granted; patched build → rejected.

Fix: nginx 1.27.4 / 1.26.3 re-checks the certificate on resumption. (CVSS ~4.3, CWE-863.)

CVE-2024-37309 · CrateDB · denial of service (CPU)

CPU exhaustion via client-initiated renegotiation

What it is: the TLS endpoint (port 4200) lets the client keep requesting renegotiation of the TLS parameters during a session. Each renegotiation costs the server CPU, so repeated requests overload it and disrupt service.

Demo: we open a TLS session and drive repeated renegotiations (e.g. **openssl s_client** ‘R’ / a short loop) while watching server CPU rise. A TLS 1.3 endpoint refuses renegotiation outright — nothing to abuse.

Fix: CrateDB 5.7.2; disable client-initiated renegotiation / require TLS 1.3. (CVSS 5.3.)

CVE-2025-66491 · Traefik · improper certificate validation

“Verify = on” that turned verification off

What it is: in Traefik’s ingress-nginx provider the **proxy-ssl-verify** annotation logic is inverted. Setting it to **“on”** sets Go’s **InsecureSkipVerify = true**, so Traefik stops checking the backend’s TLS certificate — exposing HTTPS backends to a man-in-the-middle, while operators believe they are protected.

Demo: a small local Kubernetes runs Traefik with that provider and an HTTPS backend presenting an untrusted cert. On the vulnerable build the connection is accepted (verification off); on the patched build it is rejected.

Fix: Traefik 3.6.3 (affected 3.5.0–3.6.2). CWE-295; CVSS 5.9. Needs a bit more setup (a k3d/kind cluster).

Plan & what we show today

At this meeting

- Environment built and running
- Tools installed and working
- Vulnerable + patched images pulled
- Servers start and accept TLS
- Ready to run the experiments

Next meeting

- Testbed setup documented
- Experiments run: vulnerable vs patched
- Results as screenshots / code / figures
- Practical part complete, ready for the report